

CyberVerse AI - Product Requirements Document (PRD)

Product: CyberVerse AI - Learn. Practice. Get Certified. Get Hired.

Stage: MVP live (v1.x) | Owner: Gaurav Malhotra | URL: app.grcwithgaurav.com

1.1 Problem

Cybersecurity job seekers study generic curricula while recruiters reject them for unknown, specific gaps. There is no feedback loop between a user's resume, interview performance, and daily study plan.

1.2 Positioning

Not a lab platform (no head-on competition with TryHackMe/HTB). An AI-powered personal career mentor accompanying users from beginner to professional.

1.3 Target Personas

Persona	Goal	Key need
Aspiring SOC Analyst (student/career-changer)	First job	Know what is missing + practice interviews
GRC professional	Cert + role growth	ISO 27001/GRC interview prep
Early-career Security Engineer	Better job	Targeted skill closure + resume polish

1.4 Core Value Loop (Weak Topics Loop)

Resume review -> AI detects gaps -> gaps stored as Weak Topics -> Daily Ops + Mentor + Interviews personalize to those topics -> performance updates Weak Topics -> repeat.

1.5 Shipped Feature Requirements

#	Story	Acceptance criteria (met)
R1	Account: sign up / log in / reset password via email	JWT session; generic reset response (no user enumeration)
R2	AI Mentor chat with persistent context (skill, certs, goals, weak topics)	Context injected per request
R3	Daily Ops bundle (lesson, quiz, news, challenge, interview Q, task) + 7 AM email	Personalized to weak topics; cron delivery
R4	Resume review: score, ATS issues, gaps, rewritten bullets	Gaps merge into Weak Topics
R5	Mock interview: 4 roles, 6 turns, per-turn feedback, score /100 + verdict	Session resume; question memory; shareable scorecard PNG + LinkedIn copy
R6	Gamification: XP, streaks, levels, Achievements Wins Wall	XP on actions; streak on daily activity
R7	Monetization: Free (3 interviews/3 reviews) to Pro Rs 499 lifetime	Paywall modal; Razorpay link; webhook auto-upgrade (HMAC-verified)
R8	Growth: landing page, welcome email, shareable scorecard	Signup to welcome email under 5 s
R9	Founder Console: signups, Pro conversion, engagement metrics	Admin-email allowlist only

1.6 Monetization

- Free: Mentor, Daily Ops, 3 interviews, 3 reviews.
- Pro Rs 499 (lifetime): unlimited interviews/reviews, PRO badge.
- Planned Premium Rs 999: PDF certificates, advanced analytics. Enterprise: later.

1.7 Success Metrics (KPIs)

Signups/week; D1/D7 retention; interview start-to-completion rate (top priority); Free-to-Pro conversion (target 5%+); scorecard shares/week; active-today.

1.8 Roadmap (Out of Scope now)

Phase 2: browser labs, AI lab assistant, GRC workspace (B2B). Phase 3: jobs portal, marketplace. Near-term: SEO pages, referrals, Premium certs, mobile.

CyberVerse AI - Technical Architecture Document

2.1 High-Level Diagram

2.2 Data Model (key columns)

Table	Key columns
users	email, hashed_password, full_name, skill_level, certifications[], weak_topics[], learning_goals, xp, streak_days, last_active_date, is_pro, is_premium, created_at
mentor_messages	user_id, role, content
daily_bundles	user_id, date, content(JSON)
resume_reviews	user_id, role, review(JSON)
interview_sessions	user_id, role, status(active/completed), overall_score
interview_turns	session_id, speaker, content, feedback
achievements	user_id, type, title, date

2.3 API Surface (principal endpoints)

Method	Path	Purpose
POST	/api/auth/signup, /login, /forgot-password, /reset-password	Auth
GET	/api/profile/me	Profile incl. is_pro
POST	/api/mentor/chat	Context-aware mentor
GET	/api/daily/today	Daily bundle
POST	/api/resume/review	Resume analysis
POST	/api/interview/start, /{id}/respond	Interview lifecycle
GET	/api/interview/active	Session resume
POST	/api/webhooks/razorpay	HMAC-verified upgrade
GET	/api/admin/stats	Founder metrics (allowlist)

2.4 Deployment and Ops

GitHub push -> Render build -> Alembic migrations -> idempotent runtime ALTER safety net -> Gunicorn serve.
Config via pydantic-settings.

2.5 Environment Variables

DATABASE_URL, JWT_SECRET, ANTHROPIC_API_KEY, RESEND_API_KEY, RESEND_FROM_EMAIL, RAZORPAY_WEBHOOK_SECRET, ADMIN_EMAIL(S), APP_BASE_URL, RATE_LIMIT_*

2.6 Scaling Path

Stateless API -> horizontal workers; extract cron to external scheduler/queue; Redis for rate-limit + cache; S3/R2 for resume files; CDN for static assets; read replicas when needed.

CyberVerse AI - Security and Access Document

3.1 Authentication and Authorization

- Passwords: salted hash (bcrypt-family), never plaintext.
- Sessions: JWT bearer (cv_token); expiry enforced; invalid token -> clean re-login.
- Password reset: signed short-lived tokens; generic response prevents account enumeration.
- Authorization: per-user row filtering (user_id scoping) on all data endpoints.
- Admin: email allowlist (ADMIN_EMAIL list) on /api/admin/*; 403 otherwise.

3.2 Payments Security

- Card data never touches the app (Razorpay-hosted) -> minimal PCI scope.
- Webhooks verified via HMAC-SHA256 (X-Razorpay-Signature); invalid -> 400.
- Upgrades idempotent; amount-based tiering (49900 -> Pro; 99900 -> Premium).

3.3 Controls Matrix

Control	Status
TLS everywhere (Render)	Done
Rate limiting (slowapi) on auth + AI	Done
ORM parameterized queries (SQLi)	Done
Secrets in platform env, not repo	Done
Email failures non-raising (no info leak)	Done
Server-side entitlement checks	Done

3.4 Known Risks and Remediations

Risk	Severity	Remediation
XSS via innerHTML rendering of AI text	High	Escape/DOMPurify all AI/user content (CV-105)
Password-reset link points to / not /app.html	High	Fix link + token handler (CV-126)
No signup email verification	Medium	Verify step (CV-130)
JWT default secret if env missing	Medium	Fail-fast on default in prod
Resume text retained indefinitely	Medium	Retention/deletion policy (CV-135)
Admin = email allowlist only	Low	Add 2FA/magic-link later
No audit log	Low	Log admin + webhook events (CV-134)

3.5 Compliance Notes

PCI-DSS out of scope via Razorpay. Publish Privacy Policy + Terms (CV-135). Support data-deletion requests (DPDP/GDPR posture). Transactional email only (Resend).

CyberVerse AI - Frontend Specification Document

4.1 Pages

Route	Purpose
/	Marketing landing (hero, loop explainer, features, pricing, CTAs)
/app.html	Auth screen + app shell (all product views)
/admin.html	Founder console (stats, charts, signups)

4.2 Design System

- Theme: dark-only. BG #0a0a0a, surfaces #151515, borders #222.
- Accent: neon teal #00ffcc; Pro: gold-orange gradient #f5af19 to #f12711.
- Type: Inter (UI) + IBM Plex Mono / Consolas (brand, labels, code).
- Components: nav-item, status-bar, cards, chat-shell, modal-overlay (paywall, scorecard), badges (pro-badge), primary/secondary buttons.

4.3 View Map (/app.html)

view-dashboard (snapshot + learning paths); view-mentor (chat); view-daily (bundle); view-resume (form + review); view-interview (setup vs session, interview-new button); view-achievements; view-profile. Modals: paywall-modal, scorecard-modal.

4.4 State and Client Behavior

- Token: localStorage cv_token; profile in-memory per session.
- API_BASE: same-origin in prod; http://127.0.0.1:8000 on localhost.
- Boot: token -> enterApp(); 401 -> clean logout state.
- Navigation: goToView(); interview view auto-checks GET /api/interview/active.
- Scorecard: client-side canvas render 1080x1350 PNG + clipboard LinkedIn post.

4.5 Key Flows

1. Auth: login/signup JSON -> access_token -> shell.
2. Interview: start -> 6 turns -> completion -> score modal -> share.
3. Paywall: free-limit hit -> modal -> Razorpay link -> webhook flips entitlement -> UI hides CTA, shows PRO badge.

4.6 Quality Requirements

Responsive (landing done; app shell mobile nav = debt); A11y focus states + aria labels (debt); vanilla JS, edits must stay idempotent and null-safe.

CyberVerse AI - Feature Ticket List

Shipped (record)

AUTH-1 JWT auth + reset; MEN-1 mentor; DLY-1 daily ops + cron email; RES-1 resume review; INT-1..5 interviews, resume-session, memory, score; GAM-1 XP/streaks/achievements; PAY-1..3 gate, paywall, webhook upgrade; GRW-1..4 landing, welcome email, scorecard share, founder console.

Backlog

ID	Title	Description	Pri	Size
CV-104	Parse verdict text into scorecard	Fill empty verdict line from closing remarks	P0	S
CV-105	Sanitize AI-rendered HTML (XSS)	Escape/DOMPurify all AI + user content	P0	M
CV-126	Fix password-reset deep link	Point to /app.html?reset_token= + handler	P0	S
CV-101	Programmatic SEO question pages	/questions/* pages funneling to signup	P1	L
CV-102	Resume review share card	Second viral loop (resume score PNG)	P1	M
CV-103	Referral engine	+1 free interview both sides	P1	M
CV-110	Premium tier Rs 999	Amount-based webhook tiering + UI	P1	M
CV-111	PDF certificates (reportlab)	Premium perk on completed interviews	P1	M
CV-121	Abandoned-interview nudge email	Lift start-to-completion rate	P1	S
CV-123	Mobile app shell + bottom nav	Responsive product views	P1	M
CV-135	Terms and Privacy pages	Legal baseline for payments	P1	S
CV-120	Day-3/Day-7 nurture emails	Retention drip	P2	S
CV-122	Skill radar chart	Visual weak-topic radar on dashboard	P2	M
CV-124	Toast system	Replace alerts	P2	S
CV-130	Signup email verification	Anti-abuse	P2	M
CV-131	External cron for daily email	Off-process scheduler	P2	M
CV-132	Redis rate-limit + cache	Scale control plane	P2	M
CV-133	S3/R2 resume storage	Persist uploads	P2	M
CV-134	Audit log	Admin + webhook events	P2	S
CV-201	Labs architecture spike	Containers/WebSockets feasibility	P3	L
CV-202	GRC workspace MVP	Risk register, assets, evidence (B2B)	P3	XL
CV-203	Jobs board MVP	Postings + candidate profiles	P3	L
CV-204	Marketplace MVP	Expert templates/courses w/ commission	P3	XL
CV-205	Mobile (PWA/Flutter spike)	App-store path	P3	L

Sprint suggestion

P0 trio (CV-104/105/126) -> CV-101 + CV-102 (growth) -> CV-110/111 (revenue).